Análise de arquivo suspeito

Share

codigo.py

PY

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Lendo o conteúdo do arquivo antes de analisá-lo

Vou começar lendo o arquivo para analisar o conteúdo.

Ran 4 commands, read a file

Veredito: o arquivo é malware, mais especificamente um ransomware com componente destrutivo. Não o execute.

Fiz uma triagem do arquivo, sem rodá-lo, e o raciocínio foi este:

1. **Tipo e tamanho.** É um script Python de cerca de 42 KB e 1.292 linhas, em texto puro. Enquanto ninguém o executa, ele não causa dano, e só ler ou guardar o arquivo é seguro.
2. **Imports.** O script combina acesso profundo ao Windows (`win32api`, `ctypes` com `kernel32` e `ntdll`), criptografia AES, envio de dados por rede e e-mail (`requests`, `smtplib`) e manipulação de processos (`psutil`, `subprocess`). Um script legítimo raramente junta tudo isso.
3. **Configuração no topo do arquivo.** Há um valor de resgate (5000), um endereço de carteira Ethereum, a extensão `.Liushen` para os arquivos cifrados e uma URL de servidor de comando e controle. Esse é o conjunto clássico de configuração de ransomware.
4. **Estrutura do código.** A classe principal se chama `LiushenRansomware`, e as demais correspondem às etapas de um ataque típico:
   - evasão de análise (detecção de VM, debugger e sandbox) e *process hollowing* para se esconder;
   - criptografia de arquivos em todos os discos, com exclusão segura dos originais;
   - apagamento das cópias de sombra, o que impede a recuperação;
   - bloqueio do MBR, que pode deixar o computador sem inicializar;
   - quatro mecanismos de persistência (registro, pasta de inicialização, agendador de tarefas e serviço);
   - envio da chave mestra e do ID da vítima para o atacante;
   - geração da nota de resgate, encerramento de processos e desativação de proteções de segurança.

5. **Existe alguma explicação benigna?** Não encontrei nenhuma. Apagar backups, sobrescrever o MBR, desligar antivírus e enviar a chave de criptografia para fora não têm uso legítimo juntos. A URL do servidor é um marcador de posição (`your-c2-server.com`), então o arquivo parece um modelo ou kit ainda não configurado. Isso não o torna inofensivo, porque a capacidade está completa e basta alguém preencher a configuração.

Não vou detalhar como cada componente funciona por dentro, porque seria explicar código de ransomware funcional, o que não faço aqui nem com motivo legítimo. Se você precisa de engenharia reversa completa, o caminho é um ambiente isolado e uma equipe de análise de malware ou resposta a incidentes. Se achar que esse limite não faz sentido no seu caso, o botão de polegar para baixo envia o feedback à Anthropic.

O que eu faria agora:

- **Não execute o arquivo**, principalmente em Windows com `pywin32` e `pycryptodome` instalados.
- **Descubra a origem.** Se veio por e-mail, mensagem ou download, apague o arquivo e avise o remetente ou o time de TI, pois a conta ou o site de origem pode estar comprometido.
- **Consulte a reputação** pelo hash SHA-256, que você pode colar no VirusTotal sem enviar o arquivo: `7b08a073dca287817bdc706d3d2a9c032259351df4fd8ee6f2d0abb249149616`.
- **Se já executou**, desconecte a máquina da rede imediatamente, não pague resgate e chame um profissional de segurança. Sinais de infecção são arquivos com extensão `.Liushen` e notas de resgate novas. Restaure a partir de backups offline.

Se você me disser de onde o arquivo veio, posso ajudar a avaliar o risco da situação.

Qual é a categoria principal deste malware?

Comparando traços de ransomware e wiper ▸

A categoria principal é **ransomware**, mais precisamente um *crypto-ransomware*, que cifra os arquivos da vítima e exige pagamento em criptomoeda (Ethereum) para devolvê-los. Isso aparece na classe principal `LiushenRansomware`, no valor de resgate, na carteira de pagamento, na extensão `.Liushen` e na geração de notas de resgate.

Ele também tem características de outras categorias, mas elas são secundárias e servem ao ataque principal:

- **Wiper (destrutivo):** o bloqueio do MBR e a exclusão segura dos originais podem tornar o sistema e os dados irrecuperáveis, mesmo que a vítima pague.
- **Exfiltração de dados:** ele envia a chave mestra e informações da vítima ao atacante.
- **Evasão e persistência:** anti-análise, *process hollowing* e mecanismos para sobreviver a reinicializações.

Em termos de MITRE ATT&CK, os comportamentos centrais são *Data Encrypted for Impact* (T1486) e *Inhibit System Recovery* (T1490), este último pelo apagamento das cópias de sombra. O bloqueio do MBR se encaixa em *Disk Structure Wipe* (T1561.002).

Resumindo, é um ransomware híbrido, com componentes destrutivos acima do comum na categoria.